

0.1 Phương pháp xây dựng luật phát hiện S7comm

Chương này trình bày thiết kế tập luật Suricata phát hiện hành vi tấn công trên giao thức Siemens S7comm, căn cứ phân tích lưu lượng ở Chương ???. Phương pháp thuộc nhóm *phát hiện dựa trên chữ ký*: mỗi luật khớp tổ hợp byte cố định trong payload TCP/102 (TPKT, COTP, S7 Header, mã chức năng).

Toàn bộ luật nằm tại `detect/rules/s7comm.rules`. Mã sid phân theo nhóm: 100000x (thiết lập phiên, trình sát), 100001x (đọc ghi biến), 100002x (download upload block), 100003x (điều khiển Start/Stop).

0.2 Luật chung để nhận diện giao thức S7comm

S7comm trên TCP/102 có cấu trúc TCP → TPKT → COTP → S7comm. Bảng 1 liệt kê offset byte dùng trong luật.

Bảng 1: Offset byte trong payload TCP/102 (S7comm Data TPDU)

Offset	Giá trị	Trường
0–1	03 00	TPKT
4–6	02 F0 80	COTP Data TPDU
7	32	S7 protocol id
8	01/03/07	ROSCTR: Job / Ack_Data / Userdata
17	—	Function code (Job, Userdata)
19	—	Function code (Ack_Data)

0.2.1 Điều kiện về chiều truyền và loại PDU

Trong môi trường thí nghiệm, PLC lắng nghe cổng TCP/102 và được mô hình hóa là *server*; trạm HMI và trạm tấn công đóng vai trò *client*. Suricata phân biệt hai lớp điều kiện trước khi khớp mã chức năng cụ thể: (i) điều kiện `flow`, xác định chiều truyền so với server TCP/102; (ii) điều kiện `content`, xác định loại PDU S7comm (Job, Userdata hoặc Ack_Data) và vị trí byte mã chức năng.

PDU Job — chiều client → PLC. Các thao tác client khởi phát (Setup Communication, Write Var, Request Download, PLC Control, ...) được đóng gói dưới dạng Job với ROSCTR=0x01. Luật tương ứng áp dụng:

- `flow:to_server,established`: giới hạn phạm vi tối gói tin client gửi tới cổng 102 của \$HOME_NET, trong phiên TCP đã thiết lập;
- `content:"|02 F0 80 32 01|"; offset:4; depth:5`: xác nhận header COTP Data TPDU (02 F0 80), mã giao thức S7 (32) và trường ROSCTR mang giá trị Job (0x01).

Đối với nhóm lệnh Userdata (Read SZL, List blocks), trường ROSCTR nhận giá

trị 0x07; mẫu tại offset 4 tương ứng là |02 F0 80 32 07|. Với cả Job và Userdata, byte mã chức năng nằm tại offset 17 (Bảng 1).

PDU Ack_Data — chiều PLC → client. Phản hồi của PLC (xác nhận ghi, trả dữ liệu block, ...) sử dụng ROSCTR=0x03. Luật tương ứng áp dụng:

- flow:from_server,established: giới hạn phạm vi tới gói tin phát sinh từ cổng 102 của PLC;
- content:"|02 F0 80 32 03|"; offset:4; depth:5: xác nhận PDU thuộc loại Ack_Data.

Khác với Job/Userdata, phần Parameter của Ack_Data đứng sau hai byte *error class* và *error code*; do đó mã chức năng được đặt tại offset 19 thay vì offset 17. Quy ước này được sử dụng thống nhất trong các luật quan sát chiều phản hồi (ví dụ sid:1000026, sid:1000013).

Ba nguyên tắc trên nhằm loại bỏ lưu lượng TCP/102 không mang S7comm, phân tách rõ chiều yêu cầu và chiều phản hồi, đồng thời đặt điều kiện content tại offset phù hợp trước khi định nghĩa chữ ký cho từng kịch bản tấn công ở Mục 0.3.

0.3 Luật theo kịch bản tấn công

0.3.1 Reconnaissance

Căn cứ Mục ??: quét TCP/102 (Nmap s7-info), đọc SZL (0x0011, 0x001c), liệt kê block (Snap7).

Luật sid:1000001.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Setup Communication to PLC";  
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;  
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|F0|";  
  offset:17; depth:1; sid:1000001; rev:1;  
  metadata:service iso-tsap, protocol s7comm, attack reconnaissance; priority:3;)
```

Phân tích. Khớp Job (ROSCTR=0x01) với function 0xf0 (Setup Communication)—bước bắt buộc trước mọi thao tác S7comm trong các kịch bản Chương 3. sid:1000001 không đủ để kết luận tấn công; dùng làm dấu hiệu mở phiên hoặc tương quan với các sid trình sát tiếp theo.

Luật sid:1000002.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Read SZL request -  
PLC  
information enumeration"; flow:to_server,established; content:"|03 00|";  
  offset:0; depth:2; content:"|02 F0 80 32 07|"; offset:4; depth:5;
```

```
content:"|00 01 12 04 11 44 01 00|"; offset:17; depth:8; sid:1000002; rev:1;  
metadata:service iso-tsap, protocol s7comm, attack reconnaissance; priority
```

Phân tích. ROSCTR=0x07 (Userdata) và mẫu |00 01 12 04 11 44 01 00| xác định nhóm CPU functions, subfunction Read SZL. sid:1000002 phát hiện mọi yêu cầu đọc SZL; các sid:1000003 và sid:1000004 tinh chỉnh theo SZL-ID quan sát trong PCAP reconnaissance.

Luật sid:1000003.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Read SZL module identific  
0x0011"; flow:to_server,established; content:"|03 00|"; offset:0; depth:2;  
content:"|02 F0 80 32 07|"; offset:4; depth:5;  
content:"|00 01 12 04 11 44 01 00|"; offset:17; depth:8;  
content:"|00 11 00 01|"; distance:0; within:12; sid:1000003; rev:1;  
metadata:service iso-tsap, protocol s7comm, attack reconnaissance; priority
```

Phân tích. Bổ sung |00 11 00 01| (SZL-ID 0x0011, index 0x0001)—trường module identification (order number CPU) trong output Nmap s7-info. sid:1000003 chứng minh fingerprint PLC cụ thể hơn sid:1000002.

Luật sid:1000004.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Read SZL communication st  
0x001c"; flow:to_server,established; content:"|03 00|"; offset:0; depth:2;  
content:"|02 F0 80 32 07|"; offset:4; depth:5;  
content:"|00 01 12 04 11 44 01 00|"; offset:17; depth:8;  
content:"|00 1C 00 00|"; distance:0; within:12; sid:1000004; rev:1;  
metadata:service iso-tsap, protocol s7comm, attack reconnaissance; priority
```

Phân tích. Khớp SZL-ID 0x001c (communication status): serial number, system name, module type—khớp bước thu thập metadata PLC trong reconnaissance.

Luật sid:1000005.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM List Blocks request -  
PLC block  
inventory enumeration"; flow:to_server,established; content:"|03 00|";  
offset:0; depth:2; content:"|02 F0 80 32 07|"; offset:4; depth:5;  
content:"|00 01 12 04 11 13 01 00|"; offset:17; depth:8; sid:1000005; rev:1;  
metadata:service iso-tsap, protocol s7comm, attack reconnaissance; priority
```

Phân tích. Mẫu |00 01 12 04 11 13 01 00|: function group Block functions, subfunction List blocks. Tương ứng scanBlock.py(.list_blocks()). Đánh dấu giai đoạn kiểm kê OB/DB/FC/FB trước upload/download hoặc khai thác sâu.

0.3.2 Phát lại lệnh Start/Stop PLC

Căn cứ Mục ??: replay payload PLC Control 0x28 và PLC Stop 0x29, PI-Service P_PROGRAM.

Luật sid:1000030.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM PLC Control command";
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|28|";
  offset:17; depth:1; sid:1000030; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack plc_control; priority:1;)
```

Phân tích. Phát hiện mọi lệnh PLC Control (0x28): Start CPU, activate block, copy RAM to ROM, priority:1 phản ánh mức độ nghiêm trọng—ảnh hưởng trực tiếp trạng thái vận hành PLC.

Luật sid:1000031.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM replayed Start CPU P_PROGRAM";
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|28|";
  offset:17; depth:1; content:"P_PROGRAM"; distance:0; within:24;
  sid:1000031; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack start_stop_replay; priority:1;)
```

Phân tích. Bổ sung chuỗi ASCII P_PROGRAM trong 24 byte sau function code—khớp payload replay Start CPU từ PCAP TIA Portal. sid:1000031 chuyên biệt hơn sid:1000030 cho kịch bản replay đồ án.

Luật sid:1000032.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM PLC Stop command";
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|29|";
  offset:17; depth:1; sid:1000032; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack plc_stop; priority:1;)
```

Phân tích. Khớp function 0x29 (PLC Stop). Tương đương sid:1000030 nhưng cho lệnh dừng CPU.

Luật sid:1000033.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM replayed Stop CPU P_PROGRAM";
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|29|";
  offset:17; depth:1; content:"P_PROGRAM"; distance:0; within:24;
  sid:1000033; rev:1;)
```

```
metadata:service iso-tsap, protocol s7comm, attack start_stop_replay; priori
```

Phân tích. Đối xứng sid:1000031: Stop CPU với PI-Service P_PROGRAM.
Khớp payload replay Stop trong lab.

0.3.3 Upload và Download block

Căn cứ Mục ??: chuỗi function 0x1a–0x1f trên traffic Siemens hoặc mô phỏng Wireshark.

Luật sid:1000020.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Request Download block to  
flow:to_server,established; content:"|03 00|"; offset:0; depth:2;  
content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|1A|";  
offset:17; depth:1; sid:1000020; rev:1;  
metadata:service iso-tsap, protocol s7comm, attack program_download; priori
```

Phân tích. Khớp Request Download (0x1a): client yêu cầu PLC chuẩn bị nhận block chương trình.

Luật sid:1000021.

```
alert tcp $HOME_NET 102 -> any any (msg:"ICS S7COMM PLC requests Download Blo  
flow:from_server,established; content:"|03 00|"; offset:0; depth:2;  
content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|1B|";  
offset:17; depth:1; sid:1000021; rev:1;  
metadata:service iso-tsap, protocol s7comm, attack program_download; priori
```

Phân tích. Chiều PLC → client; Job 0x1b: PLC chủ động yêu cầu block dữ liệu download. Khác sid:1000026 về hướng và ROSCTR.

Luật sid:1000026.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM client sends Download Blo  
to PLC"; flow:to_server,established; content:"|03 00|"; offset:0; depth:2;  
content:"|02 F0 80 32 03|"; offset:4; depth:5; content:"|1B|";  
offset:19; depth:1; sid:1000026; rev:1;  
metadata:service iso-tsap, protocol s7comm, attack program_download; priori
```

Phân tích. Ack_Data (ROSCTR=0x03), function 0x1b tại offset 19: client gửi nội dung block xuống PLC. Cặp sid:1000021/sid:1000026 mô tả hai chiều của giai đoạn Download Block.

Luật sid:1000022.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Download Ended";  
flow:to_server,established; content:"|03 00|"; offset:0; depth:2;  
content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|1C|";
```

```
offset:17; depth:1; sid:1000022; rev:1;
metadata:service iso-tsap, protocol s7comm, attack program_download; priority:1;
```

Phân tích. Kết thúc chuỗi download (0x1c).

Luật sid:1000023.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Start Upload block from PLC";
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|1D|";
  offset:17; depth:1; sid:1000023; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack program_upload; priority:1;)
```

Phân tích. Start Upload (0x1d): client yêu cầu lấy chương trình từ PLC.

Luật sid:1000024.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Upload Block request";
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|1E|";
  offset:17; depth:1; sid:1000024; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack program_upload; priority:1;)
```

Phân tích. Upload Block (0x1e): truyền từng block dữ liệu từ PLC về client.

Luật sid:1000025.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM End Upload";
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|1F|";
  offset:17; depth:1; sid:1000025; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack program_upload; priority:1;)
```

Phân tích. End Upload (0x1f): kết thúc chuỗi upload.

0.3.4 Ghi biến quá trình và quan sát MITM

Căn cứ Mục ??: ghi DB1.DBW2 (iSetpoint) 0x04b0→0x07d0; can thiệp Ack_Data phía HMI.

Luật sid:1000010.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Write Var request to PLC";
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|05|";
  offset:17; depth:1; sid:1000010; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack modify_process_variable;
  priority:1;)
```

Phân tích. Function 0x05 (Write Var). Cảnh báo mọi ghi biến vào PLC—nền cho sid:1000011 và sid:1000012.

Luật sid:1000011.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Write Var to DB1.DBW2 setpoint"
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|05|";
  offset:17; depth:1; content:"|12 0A 10|"; offset:19; depth:3;
  content:"|00 01 84 00 00 10|"; offset:25; depth:6; sid:1000011; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack stuxnet_mitm_sim; priority:3;)
```

Phân tích. |12 0A 10|: Any-type; |00 01 84 00 00 10|: DB1, area DB, bit offset 0x10 (byte 2, DBW2). Khớp địa chỉ iSetpoint trong mô phỏng.

Luật sid:1000012.

```
alert tcp any any -> $HOME_NET 102 (msg:"ICS S7COMM Write Var DB1.DBW2 setpoint"
  flow:to_server,established; content:"|03 00|"; offset:0; depth:2;
  content:"|02 F0 80 32 01|"; offset:4; depth:5; content:"|05|";
  offset:17; depth:1; content:"|12 0A 10|"; offset:19; depth:3;
  content:"|00 01 84 00 00 10|"; offset:25; depth:6;
  content:"|00 04 00 10 07 D0|"; offset:31; depth:6; sid:1000012; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack stuxnet_mitm_sim; priority:3;)
```

Phân tích. |00 04 00 10 07 D0|: transport size WORD, giá trị 0x07d0 (2000). Khớp payload tấn công ghi setpoint trong lab. Chuỗi sid:1000010→sid:1000011—tăng dần độ đặc hiệu.

Luật sid:1000013.

```
alert tcp any 102 -> $HOME_NET any (msg:"ICS S7COMM suspicious Ack_Data response"
  to HMI/engineering station"; flow:from_server,established;
  content:"|03 00|"; offset:0; depth:2; content:"|02 F0 80 32 03|";
  offset:4; depth:5; sid:1000013; rev:1;
  metadata:service iso-tsap, protocol s7comm, attack possible_mitm_observation;
  threshold:type both, track by_src, count 60, seconds 10; priority:3;)
```

Phân tích. Chiều PLC→HMI, ROSCTR=Ack_Data. Chữ ký không chứng minh sửa payload MITM; threshold (60 gói/10 s) ghi nhận mật độ phản hồi cao. Cần tương quan với sid:1000012 và phát hiện ARP/L2 (ngoài tập luật S7comm).

0.3.5 Kịch bản chưa có luật

Mục ?? và Mục ?? chưa có PCAP và sid trong s7comm.rules. Khi xác định được byte đặc trưng, bổ sung nhóm 100004x theo cùng schema offset ở Mục 0.2.

0.4 Tổng hợp

Bảng 2: Ánh xạ kịch bản Chương 3 và tập `sid`

Kịch bản	<code>sid</code>	Chức năng phát hiện
Trình sát	1000001–1000005	Setup, SZL, List blocks
Start/Stop replay	1000030–1000033	0x28/0x29, P_PROGRAM
Upload/Download	1000020–1000026	0x1a–0x1f, hai chiều 0x1b
Stuxnet MITM	1000010–1000013	Write DB1.DBW2, quan sát Ack_Data
DoS / Malformed	—	Chưa triển khai

Hạn chế phương pháp chữ ký: (i) chỉ khớp biến thể đã mô tả; (ii) offset trên payload TCP giả định PDU không bị phân mảnh; (iii) lưu lượng HMI hợp lệ có thể kích hoạt `sid:1000001`, `sid:1000010`; (iv) `sid:1000013` không chứng minh MITM độc lập. Các hạn chế này là tiền đề đánh giá thực nghiệm ở chương sau.